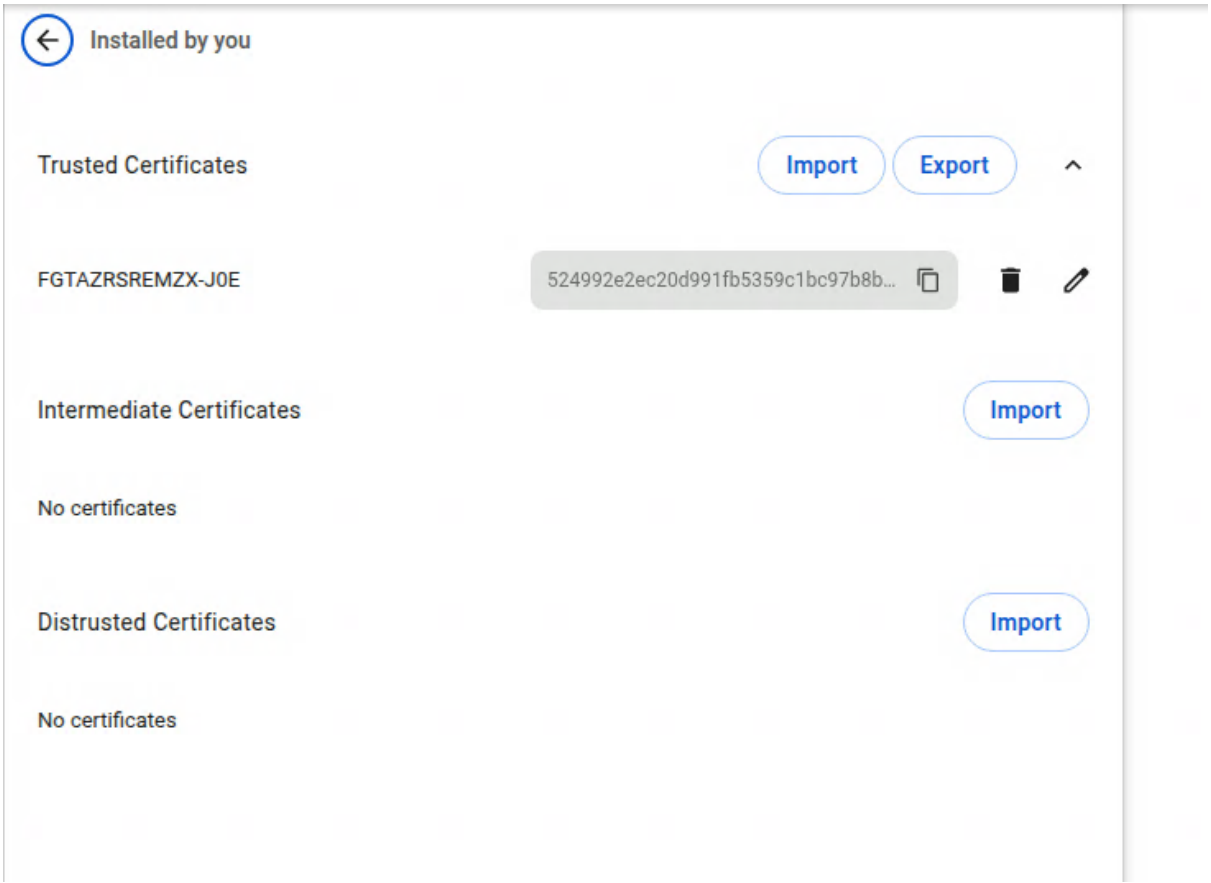
11. Security Profile laborok

Miért fontos? A firewall policy azt dönti el, hogy egy session létrejöhet-e. A Security Profile azt vizsgálja, hogy az engedélyezett sessionön belüli tartalom, fájl vagy alkalmazás elfogadható-e. A következő laborokban először megfigyelünk és naplózunk, majd célzottan blokkolunk; minden módosítás után ugyanazzal a forgalommal tesztelj, hogy a különbség a Security Profile hatásából következzen.

11.1 SSL inspection előkészítés és QUIC tiltás

1. **Cél:** előkészíteni a későbbi HTTPS tartalmi vizsgálatot úgy, hogy a Linux kliens Chromium böngészője megbízzon a FortiGate által használt SSL inspection CA tanúsítványban, valamint megakadályozni, hogy QUIC UDP/443 forgalom kerülje meg a hagyományos TLS-alapú vizsgálatot.
1. **Becsült idő:** 30–40 perc.
2. **Kiinduló állapot:** a Linux kliens internetelléréssel rendelkezik a LAN → Internet policy-n keresztül, a FortiGate admin felülete elérhető Chromiumból, és a későbbi Security Profile labok ugyanazon kimenő policyra fognak épülni.
3. **FortiGate CA tanúsítvány letöltése:** a FortiGate admin felületén keresd meg az SSL/SSH inspection profiloknál használt CA tanúsítvány letöltési lehetőségét, majd töltsd le a FortiGate által használt CA certet a Linux kliensre.



4. **CA import Chromium saját trust store-jába:** Chromiumban nyisd meg a Settings → Privacy and security → Security → Manage certificates felületet, majd importáld a letöltött FortiGate CA

tanúsítványt a Chromium saját trust store-jába. A tanúsítványt jelöld megbízhatónak webhelyek azonosításához.

5. **QUIC service létrehozása:** GUI: **Policy & Objects** → **Services** → **Create New**.
   Név: **QUIC_UDP_443**
   Type: **Custom**
   Protocol: **UDP**
   Destination port: **443**
   (IP címeket ne rendelj hozzá)
   Mentsd el a szolgáltatást.
6. **QUIC blokkoló firewall rule:** hozz létre explicit deny szabályt a LAN felől internet irányba:
   Incoming Interface: **port2**
   Outgoing Interface: **port1**
   Source: a Linux kliens vagy a LAN hálózat
   Destination: **all**
   Service: **QUIC_UDP_443**
   Action: **Deny**, NAT: disabled, Log Violation Traffic: enabled.
   A szabály legyen a LAN → Internet allow policy fölött (BOOTSTRAP-LAN-INTERNET). Ehhez érdemes átváltani a nézetet "By Sequence"-re. Ha sikerült alá betenni, akkor használd a more opciót a szabályon, és válaszd a "Move By ID" opciót.
7. **CLI ellenőrzés:** futtasd a `show firewall service custom QUIC_UDP_443` és `show firewall policy` parancsokat. Ellenőrizd, hogy a deny szabály port2 → port1 irányú, UDP/443 service-t használ, és a kimenő allow szabály fölött van.
8. **Elvárt eredmény:** a böngészés továbbra is működik TCP/443-on, de a QUIC UDP/443 forgalom blokkolva van és naplózódik. Ez stabilabb alapot ad a későbbi Web Filter, Application Control, DLP, File Filter és Antivirus labok HTTPS-vizsgálatához.
9. **Hibakeresés:** ha továbbra is QUIC látszik, ellenőrizd a policy sorrendet, az interfészirányt, a service portot, a forgalom forrását és azt, hogy a böngésző nem meglévő sessionből dolgozik-e. Szükség esetén zárd be a böngészőt, töröld az aktív sessionöket, majd ismételd meg a tesztet.

11.2 URL-szűrés labor

1. **Cél:** statikus URL/domain szabály létrehozása, először monitor módban, majd blokkolással.
2. **Becsült idő:** 25 perc.
3. **Kiinduló állapot:** a Linux kliens **10.<N>.10.10** rendelkezik internetelléréssel egy LAN → WAN policy-n keresztül.
4. **Tesztelt forgalom:** HTTP/HTTPS böngészés ártalmatlan tesztoldalra.
5. **Beállítás:** GUI: **Security Profiles** → **Web Filter** → **Create New**. Név: **WF-LAB-URL**. A Static URL Filter részben adj hozzá egy oktató által megadott domaint (reddit.com). Első körben Action: **Monitor** vagy **Allow** naplózással. Mentsd el a profilt.
6. **Policy hozzárendelés:** GUI: **Policy & Objects** → **Firewall Policy**. Nyisd meg a LAN → Internet policyt (BOOTSTRAP-LAN-INTERNET), kapcsold be a Security Profiles részt, rendeld hozzá a **WF-LAB-URL** profilt, és állítsd a naplózást **All Sessions** értékre.
7. **Ellenőrzés:** a kliensről nyisd meg a tesztoldalt, majd nézd meg: **Log & Report** → **Security Events** → **Web Filter**.
8. **Blokkolás:** módosítsd a statikus URL szabály Action értékét **Block**-ra, majd ismételd meg a böngészőtesztet.
9. **Elvárt eredmény:** monitor módban a kapcsolat működik és log keletkezik; block módban a FortiGate blokkolja az elérést és Web Filter log jelenik meg

10. **Kategória szűrés:** GUI: **Security Profiles** → **Web Filter** → **WF-LAB-URL**. A Static URL Filter részben adj hozzá egy oktató által megadott domain kategóriát (GAMBLING, példa gambling.com vagy bet365.com). Első körben Action: **Monitor** vagy **Allow** naplózással. Mentsd el a profilt.
11. **Elvárt eredmény:** monitor módban a kapcsolat működik és log keletkezik; block módban a FortiGate blokkolja az elérést és Web Filter log jelenik meg.
12. **Hibakeresés:** ellenőrizd a policy illeszkedést, a DNS feloldást, a Web Filter profil hozzárendelését, a logolást és azt, hogy a kliens valóban a FortiGate-en keresztül megy ki.
13. **Takarítás (opcionális):** állítsd vissza az URL szabályt Monitor/Allow módba vagy vedd le a profilt a policyról.
14. **Vidd el egy próbakörre:** teszteld igény szerint a feature-t, az általad érdekesnek tartott beállításokkal. Keress rá, hogy hogyan tudod megnézni a weboldalak kategóriáit, hogyan tudsz változtatást kérni.

11.3 IPS labor – alap Nmap teszt

1. **Cél:** IPS log generálása kontrollált, ártalmatlan Nmap portscan segítségével. Nem aktív sebezhetőséget használunk, hanem felismerhető szkennelési mintát.

2. **Becsült idő:** 30 perc.

3. **Kiinduló állapot:** a Linux kliens **10.<N>.10.10** eléri a DMZ szervert **10.<N>.20.10**. A LAN → DMZ policy létezik és naplóz. Nézd meg a Terminal Emulatorban, hogy az nmap alkalmazás telepítve van-e, és ha nem, akkor adj ki egy “sudo apt install nmap -y” parancsot.

4. **IPS profil:** GUI: **Security Profiles** → **Intrusion Prevention** → **Create New**. Név: **IPS-LAB-NMAP**. Hozz létre egy **Signature** szabályt monitor módban az Nmap felismeréshez. Használd az oktató által megadott FortiGuard IPS signature-t: **45360 vagy keress az NMAP kifejezésre (NMAP.Script.Scanner)**. Packet logging: **Enable**, Action: először **Monitor**. Amennyiben ez az alap policy-ben nincs benne, az azért van, mert a Forti nem frissíti a leírókat, amíg a policy nem hivatkozik rájuk. Tedd a LAN DMZ policy-re az IPS profilok közül a default policy-t, majd **System – Fortiguard – Update Licenses and Definitions now.**

5. **Policy hozzárendelés:** nyisd meg a LAN → DMZ policyt, kapcsold be az IPS profilt, válaszd az **IPS-LAB-NMAP** profilt, és állítsd a logolást **All Sessions** értékre.

6. **Teszt:** a Linux kliensről futtass nagyon alap Nmap tesztet a saját DMZ szervered felé: `nmap -sS -Pn server.s<n>.axionsec.internal`, vagy `sudo nmap server.s9.axionsec.internal -Pn -p 80,22 -v --packet-trace -sVc`

7. **Ellenőrzés:** GUI: **Log & Report** → **Security Events** → **Intrusion Prevention**. CLI: `diagnose sniffer packet any 'host 10.<N>.20.10' 4 0 l` és `diagnose sys session list`.

8. **Blokkolás:** ha monitor módban látszik a log, módosítsd a signature action értékét **Block**-ra, majd ismételd meg az Nmap tesztet.

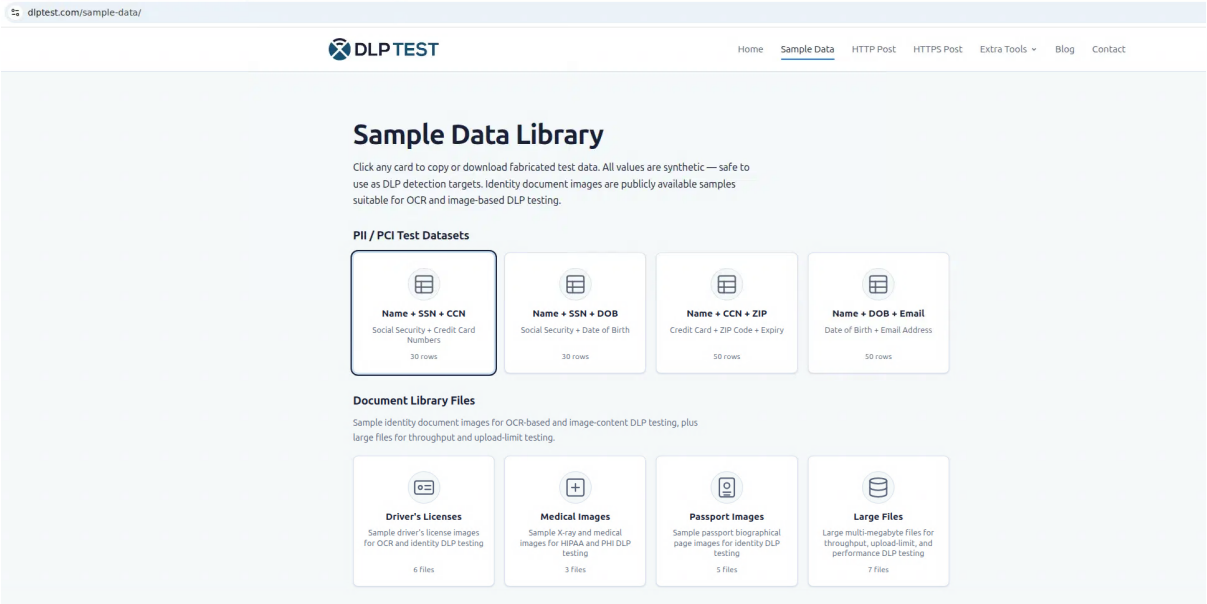
9. **Elvárt eredmény:** monitor módban IPS log keletkezik, de a scan lefut; block módban a FortiGate megszakítja vagy korlátozza a felismerhető scan forgalmat.

10. **Hibakeresés:** ellenőrizd, hogy a forgalom tényleg az IPS profilos policyra illeszkedik-e, van-e IPS licenc/signature update, nőnek-e a session számlálók, és nem kerül-e a forgalom más policyra.

11. **Takarítás:** állítsd vissza a signature actiont Monitor értékre, vagy vedd le az IPS profilt a LAN → DMZ policyról.

11.4 DLP labor – dlptest.com és XLSX teszt

1. **Cél:** DLP esemény generálása szintetikus tesztadatokkal, először naplózással, majd blokkolással. A cél nem valódi adat kiszivárogtatása, hanem annak megértése, hogy a FortiGate tartalmi minták alapján is dönthet.
2. **Becsült idő:** 35–45 perc.
3. **Kiinduló állapot:** a Linux kliens internetelléréssel rendelkezik, a LAN → Internet policy működik és naplóz. A laborhoz szintetikus mintaadatokat használj, például, tesztelésre szolgáló kártyaszám-mintákat. Ezek nem valódi ügyféladatok. Amennyiben a Data Loss Prevention nem látszik, kapcsold be a System – Feature Visibility alatt.
4. **Tesztelt forgalom:** HTTP alapú fájlletöltés vagy feltöltés a **dlptest.com** tesztoldalról. Az XLSX fájl használható DLP és File Filtering demonstrációhoz is.



5. **DLP profil létrehozása:** GUI: **Security Profiles** → **Data Leak Prevention** vagy **DLP** → **Create New**. Név: **DLP-LAB-AXION**. Hozz létre helyi szótárat vagy mintát a **AXION-CONFIDENTIAL** kulcsszóra, ha az adott FortiOS build ezt támogatja. Ha a pontos CLI vagy objektumszerkezet nem egyértelmű, a GUI eljárást tekintsd irányadónak.
6. **Első kör – naplózás:** a DLP szabály action értéke először **Log Only** vagy **Monitor** legyen. Rendeld hozzá a profilt a LAN → Internet policyhoz, majd kapcsold be az **All Sessions** naplózást.
7. **TXT/CSV teszt:** hozz létre egyszerű fájlt a kliensen, például `echo AXION-CONFIDENTIAL > dlp-test.txt`. Ha rendelkezésre áll HTTP feltöltési tesztoldal, töltsd fel a fájlt. Először a sima szöveges fájl működését ellenőrizd.
8. **XLSX teszt:** a dlptest.com oldalról tölts le vagy használj XLSX mintafájlt. Az XLSX fájl egy ZIP/XML konténer, ezért összetettebb ellenőrzési eset, mint a TXT vagy CSV. Csak akkor teszteld XLSX-szel, ha az egyszerű formátumokkal már látszik DLP log.
9. **Blokkolás:** ha monitor módban megjelenik a DLP esemény, módosítsd az action értékét **Block**-ra, majd ismételd meg a tesztet.
10. **Ellenőrzés:** GUI: **Log & Report** → **Security Events** → **Data Leak Prevention**. Ellenőrizd a forrás IP-t, cél oldalt, policy ID-t, profilt és action mezőt.
11. **Elvárt eredmény:** monitor módban a művelet sikerül és DLP log keletkezik; block módban a FortiGate blokkolja az adatmintát tartalmazó átvitelét, és DLP log jelenik meg.

12. **Hibakeresés:** nincs DLP profil a policyhoz rendelve; HTTPS miatt a tartalom nem látható; nincs megfelelő inspection mód; a fájl nem tartalmazza a mintát; XLSX esetén a konténer feldolgozása nem úgy történik, mint sima szövegnél; a forgalom nem azon a policyn megy át, amelyen a DLP profil aktív.
13. **Takarítás:** töröld a helyi tesztfájlokat, állítsd vissza a DLP actiont Monitor/Log Only módba, vagy vedd le a DLP profilt a policyról.

11.5 File Filtering labor – FTP és XLSX fájl

1. **Cél:** fájltípus-alapú szűrés bemutatása egyszerű, titkosítatlan FTP forgalmon. A labban TXT fájlt engedünk, egy kiválasztott fájltípust – például XLSX vagy ZIP – blokkolunk.
2. **Becsült idő:** 45 perc.
3. **Kiinduló állapot:** Linux kliens: **10.<N>.10.10**, Linux DMZ szerver: **10.<N>.20.10**. A LAN → DMZ policy létezik, de a File Filter profilt még nem kapcsoltuk hozzá.
4. **FTP szerver előkészítése a DMZ szerveren:** futtasd: `sudo apt update`, majd `sudo apt install -y vsftpd`. A minimális vsftpd konfiguráció tartalmazza: `listen=YES`, `listen_ipv6=NO`, `anonymous_enable=NO`, `local_enable=YES`, `write_enable=YES`, `pasv_enable=YES`, `pasv_min_port=30000`, `pasv_max_port=30010`, `xferlog_enable=YES`.
5. **FTP felhasználó:** hozz létre **ftpuser** felhasználót és írható upload könyvtárat. Példa: `sudo adduser ftpuser`, `sudo mkdir -p /home/ftpuser/upload`, `sudo chown ftpuser:ftpuser /home/ftpuser/upload`. Indítsd újra és engedélyezd a szolgáltatást: `sudo systemctl restart vsftpd`, `sudo systemctl enable vsftpd`.
6. **FTP alapteszt:** a kliensről hozz létre fájlt: `echo test > test.txt`. Töltsd fel curl-lel: `curl -v -T test.txt ftp://ftpuser:<password>@10.<N>.20.10/upload/test.txt`.
7. **Firewall policy:** GUI: **Policy & Objects** → **Firewall Policy**. A LAN → DMZ policyban engedélyezd az FTP-t, NAT nélkül. Ha passzív FTP-t használsz, győződj meg róla, hogy a control channel és a passzív data channel is átmegy. A FortiGate FTP helper/inspection miatt a passzív adatkapcsolatoknak is kezelhetőnek kell lenniük.
8. **File Filter profil:** GUI: **Security Profiles** → **File Filter** → **Create New**. Név: **FF-LAB-FTP**. Állítsd be, hogy TXT engedélyezett legyen, a kiválasztott teszt fájltípus – például XLSX vagy ZIP – pedig **Block** actiont kapjon. A dlptest.com oldalról letöltött XLSX fájl használható tesztfájlnak.
9. **Profil hozzárendelése:** rendeld hozzá a **FF-LAB-FTP** profilt a LAN → DMZ FTP policyhoz, és kapcsold be az **All Sessions** naplózást.
10. **Teszt:** először tölts fel TXT fájlt, majd XLSX vagy ZIP fájlt ugyanazzal a curl módszerrel. Példa: `curl -v -T sample.xlsx ftp://ftpuser:<password>@10.<N>.20.10/upload/sample.xlsx`.
11. **Elvárt eredmény:** a TXT feltöltés sikeres, a blokkolt fájltípus feltöltése sikertelen vagy megszakad. File Filter log keletkezik.
12. **Napló helye:** GUI: **Log & Report** → **Security Events** → **File Filter**, valamint **Forward Traffic**.
13. **Miért fontos?** Az FTP clear text protokoll, ezért a FortiGate képes látni a control és data csatornát. Az FTPS titkosított FTP, amely TLS inspectiont igényelhet. Az SFTP nem FTP, hanem SSH alapú protokoll, ezért másként kell kezelni.
14. **Hibakeresés:** nem fut a vsftpd; rossz jelszó vagy jogosultság; passzív portok nem elérhetők; hiányzik az FTP service a policyból; rossz policyra megy a forgalom; nincs File Filter profil hozzárendelve; HTTPS/FTPS/SFTP forgalmat próbálsz FTP labként szűrni.
15. **Takarítás:** töröld a feltöltött tesztfájlokat az upload könyvtárból, állítsd vissza a File Filter actiont monitor módba vagy vedd le a profilt a policyról.

11.6 Application Control labor – YouTube tiltás

1. **Cél:** bemutatni, hogy a FortiGate nem csak port és protokoll alapján dönthet. A TCP/443 nem feltétlenül „általános HTTPS”; az Application Control képes alkalmazás-szintű osztályozásra, ha rendelkezésre állnak a megfelelő signature-ök.
2. **Becsült idő:** 30 perc.
3. **Kiinduló állapot:** a Linux kliens internetelléréssel rendelkezik a LAN → Internet policy-n keresztül. Az Application Control signature adatbázis elérhető és friss.
4. **Tesztelt forgalom:** böngészés a YouTube felé az izolált labor internetkapcsolatán keresztül.
5. **Megfigyelő profil létrehozása:** GUI: **Security Profiles** → **Application Control** → **Create New**. Név: **APP-LAB-YOUTUBE**. Első körben ne blokkolj, csak figyeld meg az alkalmazásokat. Állítsd a releváns kategóriákat vagy alkalmazásokat **Monitor** állapotba.
6. **Policy hozzárendelés:** GUI: **Policy & Objects** → **Firewall Policy**. Nyisd meg a LAN → Internet policyt, kapcsold be az Application Control profilt, válaszd az **APP-LAB-YOUTUBE** profilt, és állítsd a naplózást **All Sessions** értékre.
7. **Első teszt:** a kliens böngészőjéből nyisd meg a YouTube-ot. Ezután nézd meg: **Log & Report** → **Security Events** → **Application Control**. Ellenőrizd, hogy a FortiGate YouTube vagy kapcsolódó Google/Video Streaming alkalmazást azonosít-e.
8. **YouTube tiltása:** térj vissza az **APP-LAB-YOUTUBE** profilhoz, keresd meg a YouTube alkalmazást vagy az oktató által megadott YouTube-hoz tartozó application signature-t, és állítsd az actiont **Block**-ra. Ha a laborban kategória alapú tiltás célszerűbb, az oktató jelölje ki a pontos kategóriát.
9. **Újrateszt:** töröld vagy frissítsd a böngésző sessiont, majd próbáld újra megnyitni a YouTube-ot. Szükség esetén indíts új böngészőablakot, hogy ne régi sessiont nézz.
10. **Elvárt eredmény:** megfigyelő módban YouTube alkalmazáslog keletkezik; blokkolás után a YouTube elérése sikertelen vagy részlegesen működésképtelen, és Application Control block log jelenik meg.
11. **Hibakeresés:** nincs Application Control profil a policyhoz rendelve; a FortiGate nem látja a teljes sessiont; a signature adatbázis hiányzik vagy régi; a forgalom más policyra illeszkedik; a böngésző cache vagy meglévő session miatt a teszt félrevezető; HTTPS/QUIC miatt más alkalmazás-azonosítási viselkedés jelenik meg.
12. **Opcionális kihívás:** bizonyítsd log alapján, hogy a blokkolt kapcsolat továbbra is TCP/443 lehet, de az alkalmazás-szintű döntés miatt nem engedélyezett.
13. **Takarítás:** állítsd vissza a YouTube actiont Monitor/Allow értékre, vagy vedd le az Application Control profilt a LAN → Internet policyról.

11.7 Opcionális Antivirus labor – EICAR

1. **Cél:** víruskeresési esemény generálása kizárólag az iparági standard, ártalmatlan EICAR tesztfájllal. Az EICAR nem kártevő, hanem vírusirtó tesztelésre szolgáló minta.
2. **Becsült idő:** 20–30 perc.
3. **Kiinduló állapot:** a Linux kliens internetelléréssel rendelkezik, az Antivirus licenc és signature állapot ellenőrizhető. Valódi malware használata tilos.
4. **Előkészítés:** GUI: **System** → **FortiGuard** vagy **Dashboard** widgetek alatt ellenőrizd az Antivirus signature állapotát.
5. **Antivirus profil:** GUI: **Security Profiles** → **AntiVirus** → **Create New** vagy meglévő profil klónozása. Név: **AV-LAB-EICAR**. HTTP inspection legyen engedélyezve, action: **Block** vagy az oktató által kijelölt blokkoló beállítás.
6. **Policy hozzárendelés:** rendeld hozzá az **AV-LAB-EICAR** profilt a LAN → Internet policyhoz, és állítsd a naplózást **All Sessions** értékre.

7. **Teszt:** a kliensről próbáld letölteni az EICAR tesztfájlt az oktató által megadott hivatalos tesztforrásból HTTP-n keresztül. Ne használj valódi malware-t, ne tölts le ismeretlen mintákat.
8. **Ellenőrzés:** GUI: **Log & Report** → **Security Events** → **AntiVirus**. Ellenőrizd a forrás IP-t, policy ID-t, fájlnevet, actiont és a signature nevét.
9. **Elvárt eredmény:** a FortiGate felismeri és blokkolja az EICAR tesztfájlt, majd Antivirus logot generál.
10. **Hibakeresés:** nincs AV profil a policyhoz rendelve; nincs vagy régi az AV signature; HTTPS forgalmat próbálsz tartalmi vizsgálat nélkül ellenőrizni; a forgalom nem azon a policyn halad át, ahol az AV profil aktív; proxy vagy cache miatt nem történik új letöltés.
11. **Takarítás:** távolítsd el az AV profilt a policyból vagy állítsd vissza az oktatói baseline-ra. Töröld a kliensen esetlegesen létrejött tesztfájlokat.